



Cyber Security & Digital Forensics

CSE - 4207

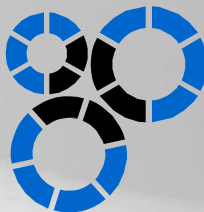
Lecture - 02

Dr. Md. Alam Hossain
Professor

Jashore University of Science & Technology

Outline

- Cyber crime and its types
- Types of Hacker
- Ethical Hacking
- Hacking Terminology
- Incident Management
- Vulnerability assessment and its types
- Penetration Testing and its types





Cyber Crime

- Offences against computer data and systems
- Illegal access: Entering a computer or account without permission.
- Illegal interception: Secretly listening to or stealing data during communication.
- Data interference: Changing, deleting, or damaging data illegally.
- System interference: Disrupting or damaging computer systems or networks.
- Misuse of devices: Using hacking tools or devices for illegal purposes.



Types of Cyber Crime

- **Hacking:** Gaining unauthorized access to a computer or network.
- Denial of service attack: Overloading a system so it stops working properly.
- Virus Dissemination: Spreading harmful software like viruses or malware.
- Computer Vandalism: Damaging or destroying computer data or systems.
- Cyber Terrorism: Using cyber attacks to create fear or harm governments and organizations.
- Software Piracy: Copying or using software illegally without permission.



Motivations of Attacks

Attacks = Motive (Goal) + Method + Vulnerability

- A motive originates out of the notion that the **target system stores or processes** something valuable and this leads to threat of an attack on the system
- Attackers try various tools and attack techniques to **exploit vulnerabilities** in a computer system or security policy and controls to achieve their motives



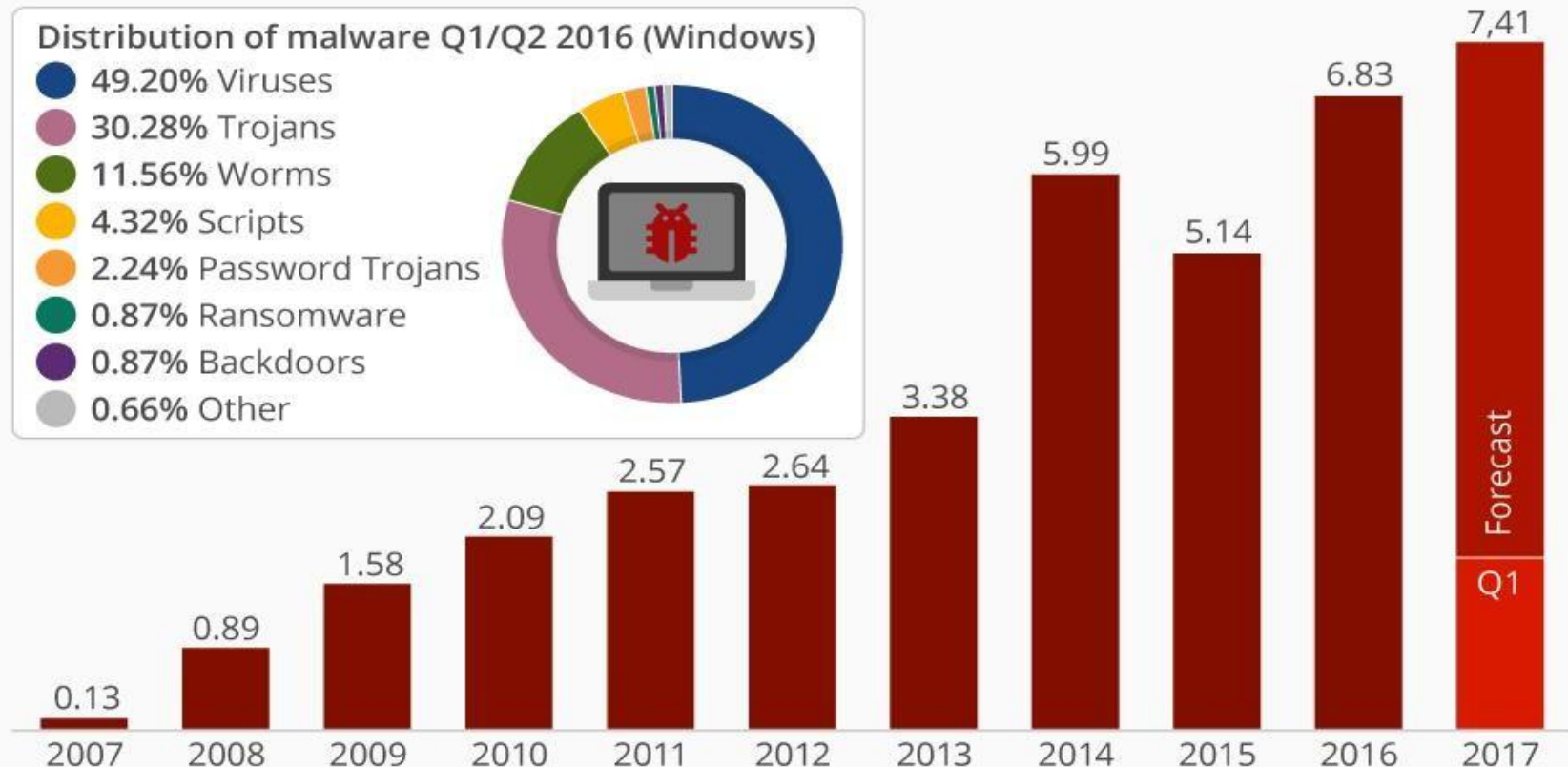
Motives Behind Information Security Attacks

- | | |
|--|--|
| • Disrupting business continuity | • Propagating religious or political beliefs |
| • Information theft | • Achieving state's military objectives |
| • Manipulating data | • Damaging reputation of the target |
| • Creating fear and chaos by disrupting critical infrastructures | • Taking revenge |

Distributed Attacks

Viruses, Worms and Trojan Horses

Number of new malware specimen (in millions)





Incidents

56 million debit and credit
card numbers were stolen



Incident occurred due
to **custom-built
malware**

Incidents





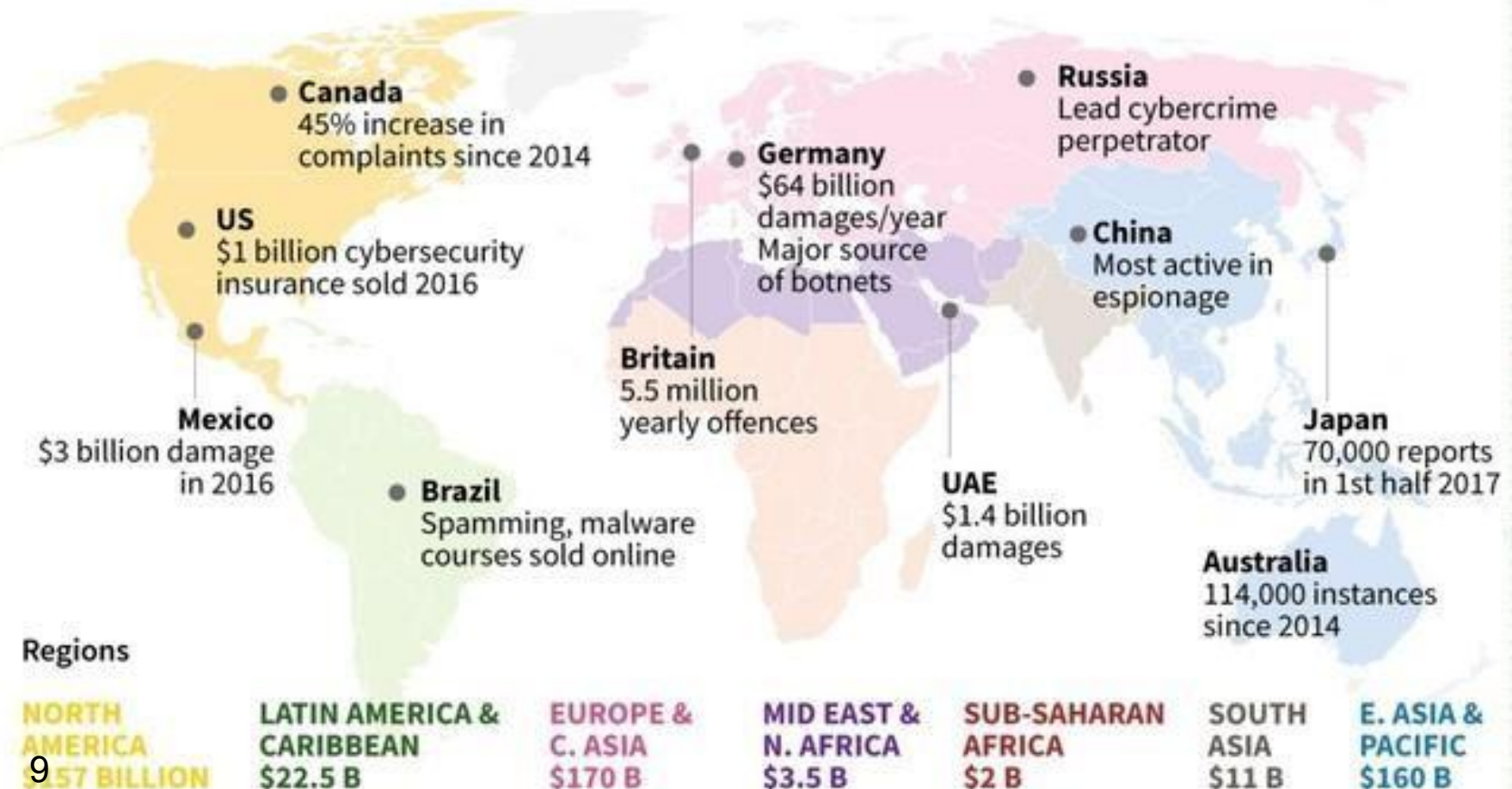
Cyber Crime Global Cost

Cybercrime highlights

Economic impact: McAfee report, February 2018

Estimated annual global cost: \$600 billion

Selected highlights



Hacking



Hacking refers to exploiting **system vulnerabilities and compromising security** controls to gain unauthorized or inappropriate access to the system resources



It involves **modifying system or application features** to achieve a goal outside of the creator's original purpose



Hacking can be used to steal, pilfer, and redistribute intellectual property leading to **business loss**

Types of Hacker

1

Black Hats

Individuals with extraordinary computing skills, resorting to malicious or destructive activities and are also known as crackers

2

White Hats

Individuals professing hacker skills and using them for defensive purposes and are also known as security analysts

3

Gray Hats

Individuals who work both offensively and defensively at various times

4

Suicide Hackers

Individuals who aim to bring down critical infrastructure for a "cause" and are not worried about facing jail terms or any other kind of punishment

5

Script Kiddies

An unskilled hacker who compromises system by running scripts, tools, and software developed by real hackers

6

Cyber Terrorists

Individuals with wide range of skills, motivated by religious or political beliefs to create fear by large-scale disruption of computer networks

7

State Sponsored Hackers

Individuals employed by the government to penetrate and gain top-secret information and to damage information systems of other governments

8

Hacktivist

Individuals who promote a political agenda by hacking, especially by defacing or disabling websites



Ethical Hacking



Ethical hacking involves the use of hacking tools, tricks, and techniques to **identify vulnerabilities** so as to ensure system security

It focuses on simulating techniques used by attackers to **verify the existence of exploitable vulnerabilities** in the system security



Ethical hackers perform security assessment of their organization **with the permission of concerned authorities**



Ethical Hacking

To beat a hacker, you need to think like one!

Ethical hacking is necessary as it **allows to counter attacks from malicious hackers** by anticipating methods used by them to break into a system

Reasons why Organizations Recruit Ethical Hackers



To **prevent hackers** from gaining access to organization's information systems

To **uncover vulnerabilities** in systems and explore their potential as a risk

To analyze and **strengthen an organization's security posture** including policies, network protection infrastructure, and end-user practices

Ethical Hacking

Ethical Hackers Try to Answer the Following Questions



What can the intruder see on the **target system**? (Reconnaissance and Scanning phases)

What can an **intruder do** with that information? (Gaining Access and Maintaining Access phases)



Does anyone at the target **notice the intruders' attempts** or successes? (Reconnaissance and Covering Tracks phases)

If all the **components of information system** are adequately protected, updated, and patched



How much effort, time, and money is required to obtain **adequate protection**?

Are the **information security measures** in compliance to industry and legal standards?



Skills of a Hacker

1 Technical Skills

- Has in-depth **knowledge of major operating environments**, such as Windows, Unix, Linux, and Macintosh
- Has in-depth **knowledge of networking** concepts, technologies and related hardware and software
- Should be a **computer expert** adept at technical domains
- Has **knowledge of security areas** and related issues
- Has **“high technical” knowledge** to launch the sophisticated attacks

2 Non-Technical Skills

Some of the non-technical characteristics of an ethical hacker include:

- Ability to learn** and adapt new technologies quickly
- Strong work ethics**, and good problem solving and communication skills
- Committed to **organization’s security policies**
- Awareness of **local standards and laws**





Hacking Terminology

Hack Value

It is the notion among hackers that **something is worth doing** or is interesting

Zero-Day Attack

An attack that exploits **computer application vulnerabilities** before the software developer releases a patch for the vulnerability

Vulnerability

Existence of a **weakness, design, or implementation error** that can lead to an unexpected event compromising the security of the system

Daisy Chaining

It involves **gaining access to one network and/or computer** and then using the same information to gain access to multiple networks and computers that contain desirable information

Exploit

A **breach** of IT system security through vulnerabilities

Doxing

Publishing personally identifiable information about an individual collected from publicly available databases and social media

Payload

Payload is the **part of an exploit code** that performs the intended malicious action, such as destroying, creating backdoors, and hijacking computer

Bot

A “bot” is a software application that can be **controlled remotely to execute or automate predefined tasks**



Hacking Terminology

Reconn-
aissance

Scanning

Gaining
Access

Mainta-
ining
Access

Clearing
Tracks

- Reconnaissance refers to the preparatory phase where an **attacker seeks to gather information** about a target prior to launching an attack
- Could be the future point of return, noted for ease of entry for an attack when more about the **target is known on a broad scale**
- Reconnaissance **target range** may include the target organization's clients, employees, operations, network, and systems

Reconnaissance Types

Passive Reconnaissance

- Passive reconnaissance involves acquiring information **without directly interacting with the target**
- For example, searching public records or news releases

Active Reconnaissance

- Active reconnaissance involves **interacting with the target directly by any means**
- For example, telephone calls to the help desk or technical department



Hacking Terminology

Reconn-
aissance

Scanning

Gaining
Access

Mainta-
ining
Access

Clearing
Tracks

18

Pre-Attack Phase

Scanning refers to the pre-attack phase when the attacker **scans the network** for specific information on the basis of information gathered during reconnaissance

Scanning can include use of dialers, **port scanners**, network mappers, ping tools, vulnerability scanners, etc.

Port Scanner

Extract Information

Attackers extract information such as **live machines**, port, port status, OS details, device type, **system uptime**, etc. to launch attack



Hacking Terminology

Reconn-
aissance

Scanning

Gaining
Access

Mainta-
ining
Access

Clearing
Tracks

Gaining access refers to the point where the attacker obtains access to the **operating system or applications** on the computer or network



The attacker can **escalate privileges** to obtain complete control of the system. In the process, intermediate systems that are connected to it are also compromised

The attacker can gain access at the **operating system level, application level, or network level**



Examples include **password cracking**, buffer overflows, denial of service, **session hijacking**, etc.



Hacking Terminology

Reconn-
aissance

Scanning

Gaining
Access

Mainta-
ining
Access

Clearing
Tracks

01

Maintaining access refers to the phase when the attacker tries to retain his or her **ownership of the system**

02

Attackers may prevent the system from being owned by other attackers by securing their exclusive access with **Backdoors**, **RootKits**, or **Trojans**

03

Attackers can upload, download, or **manipulate data**, applications, and configurations on the **owned system**

04

Attackers use the compromised system to **launch further attacks**



Hacking Terminology

Reconn-
aissance

Scanning

Gaining
Access

Mainta-
ining
Access

Clearing
Tracks

21

01

Covering tracks refers to the activities carried out by an attacker to **hide malicious acts**

02

The attacker's intentions include: **Continuing access** to the victim's system, remaining **unnoticed and uncaught**, deleting evidence that might lead to his prosecution

03

The attacker overwrites the server, system, and application logs to **avoid suspicion**

Attackers always cover tracks to hide their identity



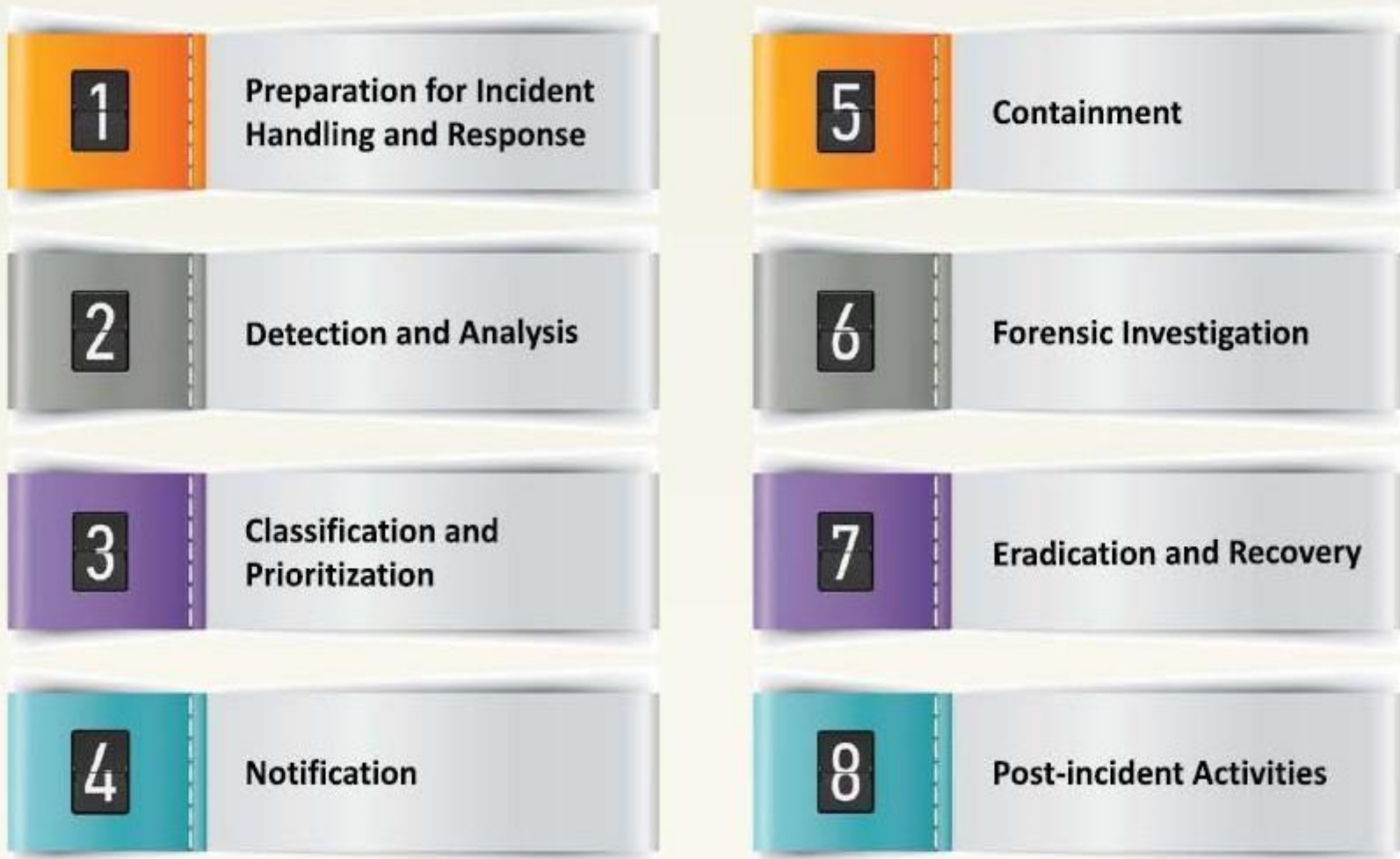
Incident Management

- Incident management is a set of defined processes to **identify**, **analyze**, **prioritize**, and **resolve security incidents** to restore normal service operations as quickly as possible and prevent future recurrence of the incident





Incident Management



○ Responsibility of Incident Management Team

Managing security issues by taking a **proactive approach** towards the customers' security vulnerabilities and **by responding effectively** to potential information security incidents

Providing a **single point of contact** for reporting security incidents and issues



Developing or reviewing the processes and procedures that must be followed in response to an incident

Reviewing **changes in legal and regulatory requirements** to ensure that all processes and procedures are valid

Managing the response to an incident and ensuring that **all procedures are followed** correctly in order **to minimize and control the damage**

Reviewing existing controls and recommending steps and technologies to **prevent future security incidents**



Identifying and analyzing what has happened during an incident, including the impact and threat

Establishing **relationship with local law enforcement agency, government agencies, key partners, and suppliers**



Vulnerability Assessment



Vulnerability assessment is an **examination of the ability of a system or application**, including current security procedures and controls, to withstand assault



It recognizes, measures, and classifies security vulnerabilities in a **computer system, network, and communication channels**

A vulnerability assessment may be used to:



Identify weaknesses that could be exploited



Predict the effectiveness of additional security measures in protecting information resources from attack



Vulnerability Assessment Types



Active Assessment

Uses a network scanner to find hosts, services, and vulnerabilities



External Assessment

Assesses the network from a hacker's point of view to find out what exploits and vulnerabilities are accessible to the outside world



Passive Assessment

A technique used to sniff the network traffic to find out active systems, network services, applications, and vulnerabilities present



Application Assessments

Tests the web infrastructure for any misconfiguration and known vulnerabilities



Host-based Assessment

Determines the vulnerabilities in a specific workstation or server



Network Assessments

Determines the possible network security attacks that may occur on the organization's system



Internal Assessment

A technique to scan the internal infrastructure to find out the exploits and vulnerabilities



Wireless Network Assessments

Determines the vulnerabilities in organization's wireless networks



Network Vulnerability Assessment Method

Phase I – Acquisition

- Collect documents required to:
 - Review **laws and procedures** related to network vulnerability assessment
 - **Identify and review document related to network security**
 - Review the **list of previously discovered vulnerabilities**

Phase II - Identification

- Conduct **interviews with customers and employees** involved in system architecture design, and administration
- Gather **technical information about all network components**
- Identify different industry standards which network security system complies to

Phase III - Analyzing

- Review interviews
- **Analyze the results** of previous vulnerability assessment
- Analyze security vulnerabilities and **identify risks**
- Perform **threat and risk analysis**
- Analyze the effectiveness of **existing security controls**
- Analyze the effectiveness of **existing security policies**





Network Vulnerability Assessment Method

Phase IV - Evaluation

- Determine the probability of exploitation of **identified vulnerabilities**
- Identify the gaps between **existing and required security measures**
- **Determine the controls** required to mitigate the identified vulnerabilities
- **Identify upgrades** required to the network vulnerability assessment process



Phase V - Generating Reports

- The result of analysis must be presented in a **draft report** to be evaluated for further variations
- **Report should contain:**
 - Task rendered by each team member
 - Methods used and findings
 - General and specific recommendations
 - Terms used and their definitions
 - Information collected from all the phases
- All documents must be **stored in a central database** for generating the final report



Vulnerability Research

- The process of **discovering vulnerabilities and design flaws** that will open an operating system and its applications to attack or misuse
- Vulnerabilities are classified based on **severity level** (low, medium, or high) and **exploit range** (local or remote)



An administrator needs vulnerability research:

To gather information about **security trends, threats, and attacks**

To find **weaknesses**, and alert the network administrator before a **network attack**

To know **how to recover** from a network attack

To **get information** that helps to prevent the security problems



Vulnerability Research Web Sites



CodeRed Center

<http://www.eccouncil.org>



Microsoft Vulnerability Research (MSVR)

<http://technet.microsoft.com>



Security Magazine

<http://www.securitymagazine.com>



SecurityFocus

<http://www.securityfocus.com>



Help Net Security

<http://www.net-security.org>



HackerStorm

<http://www.hackerstorm.co.uk>



SC Magazine

<http://www.scmagazine.com>



Computerworld

<http://www.computerworld.com>



HackerJournals

<http://www.hackerjournals.com>



WindowsSecurity

<http://www.windowsecurity.com>



Vulnerability Research Web Sites

01

Penetration testing is a method of evaluating the security of an information system or network by **simulating an attack to find out vulnerabilities** that an attacker could exploit



02

Security measures are actively analyzed for design weaknesses, technical flaws and vulnerabilities



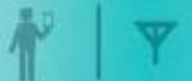
03

A penetration test will not only point out vulnerabilities, but will also **document** how the weaknesses can be exploited



04

The results are delivered comprehensively in a **report**, to executive management and technical audiences





Why Penetration Testing

Identify the threats facing an **organization's information assets**

Reduce an organization's expenditure on IT security and enhance **Return On Security Investment (ROSI)** by identifying and remediating vulnerabilities or weaknesses

Provide assurance with comprehensive **assessment of organization's security** including policy, procedure, design, and implementation

Gain and maintain certification to an **industry regulation** (BS7799, HIPAA etc.)

Adopt **best practices** in compliance to legal and industry regulations

For testing and validating the efficacy of **security protections and controls**

For changing or upgrading **existing infrastructure** of software, hardware, or network design

Focus on **high-severity vulnerabilities** and emphasize **application-level security issues** to development teams and management

Provide a comprehensive approach of **preparation steps** that can be taken to prevent upcoming exploitation

Evaluate the efficacy of **network security devices** such as firewalls, routers, and web servers

Types of Penetration Testing

01

Black-box

No prior knowledge of the infrastructure to be tested

- Blind Testing
- Double Blind Testing

02

White-box

Complete knowledge of the infrastructure that needs to be tested

03

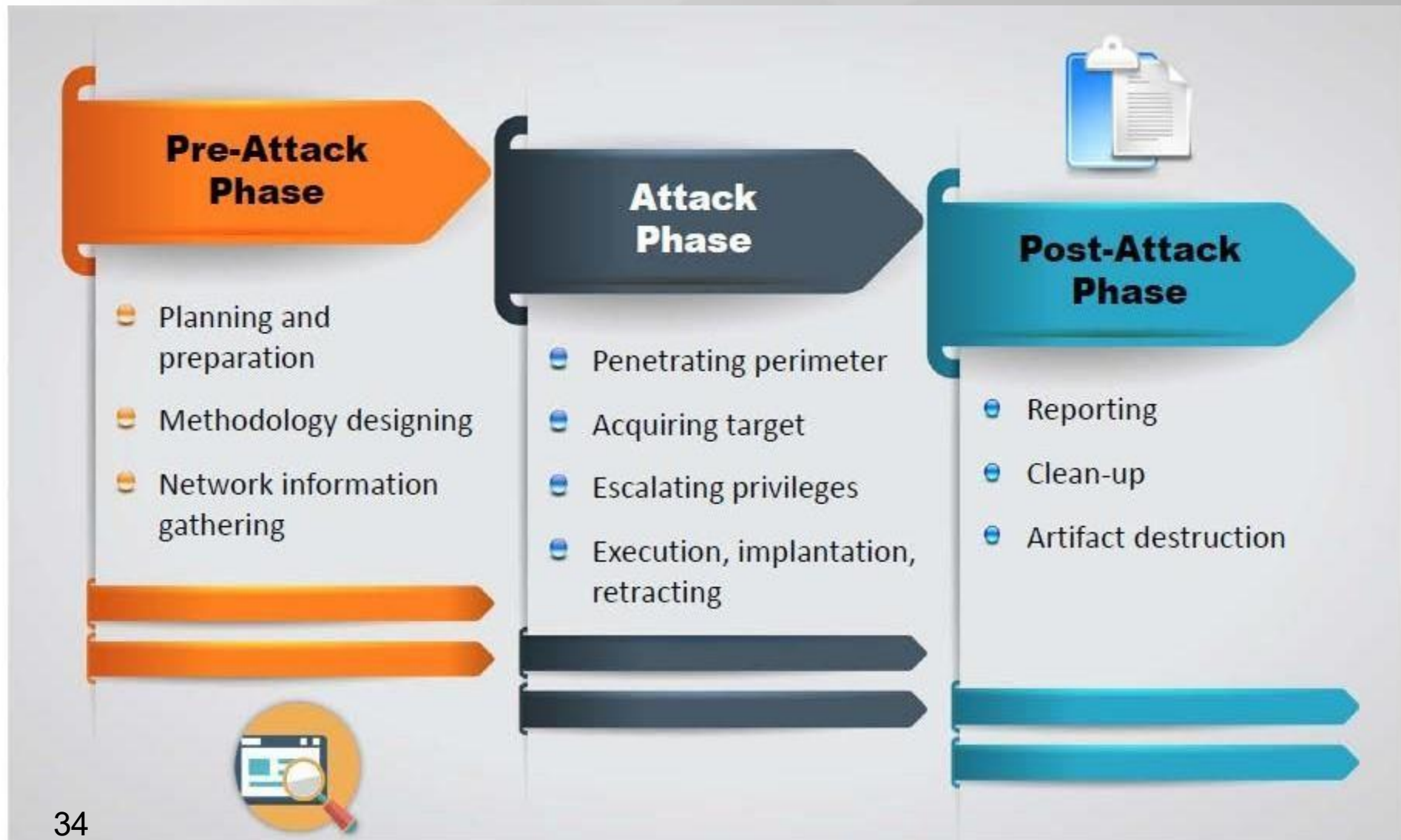
Grey-box

- **Limited knowledge** of the infrastructure that needs to be tested



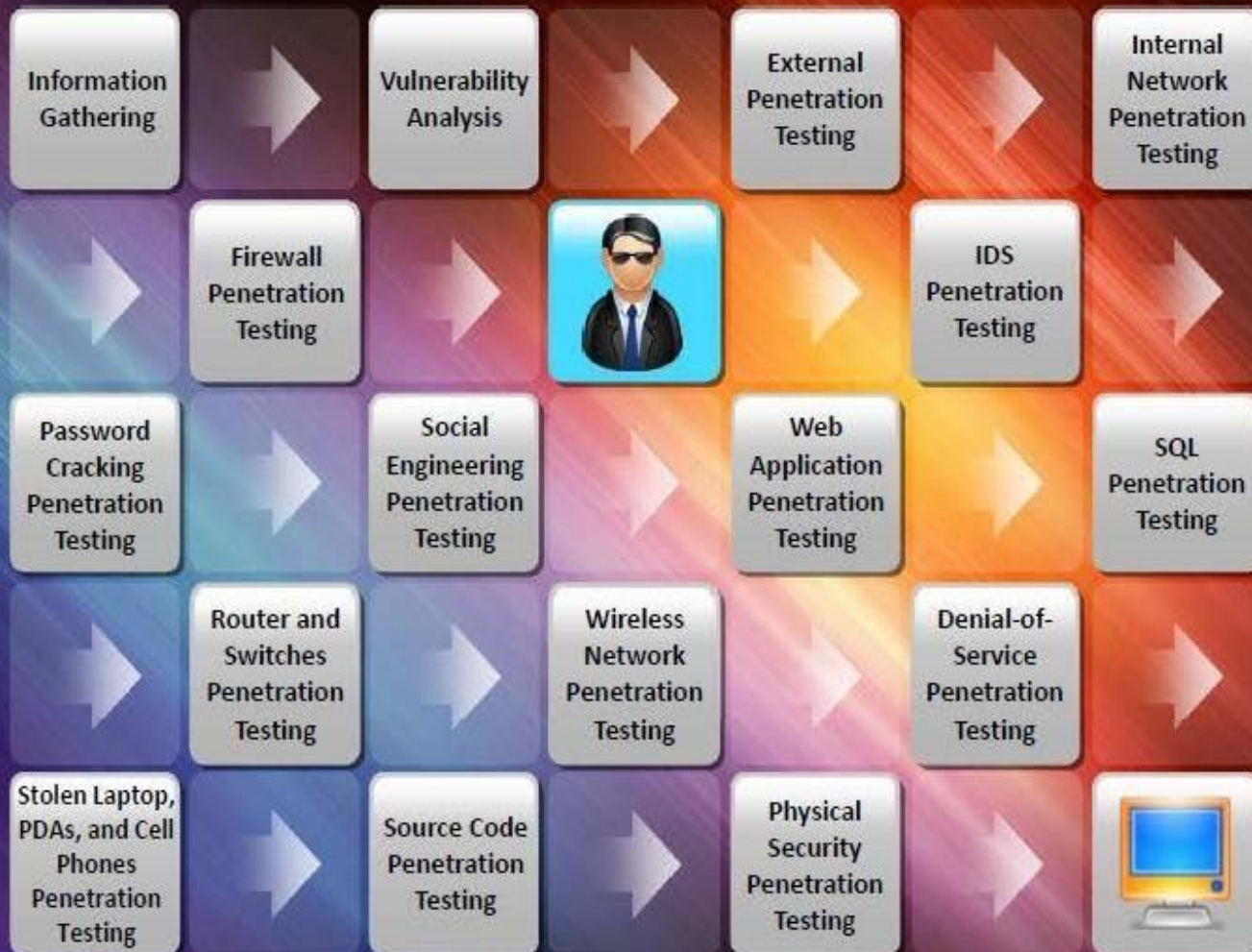


Phase of Penetration Testing



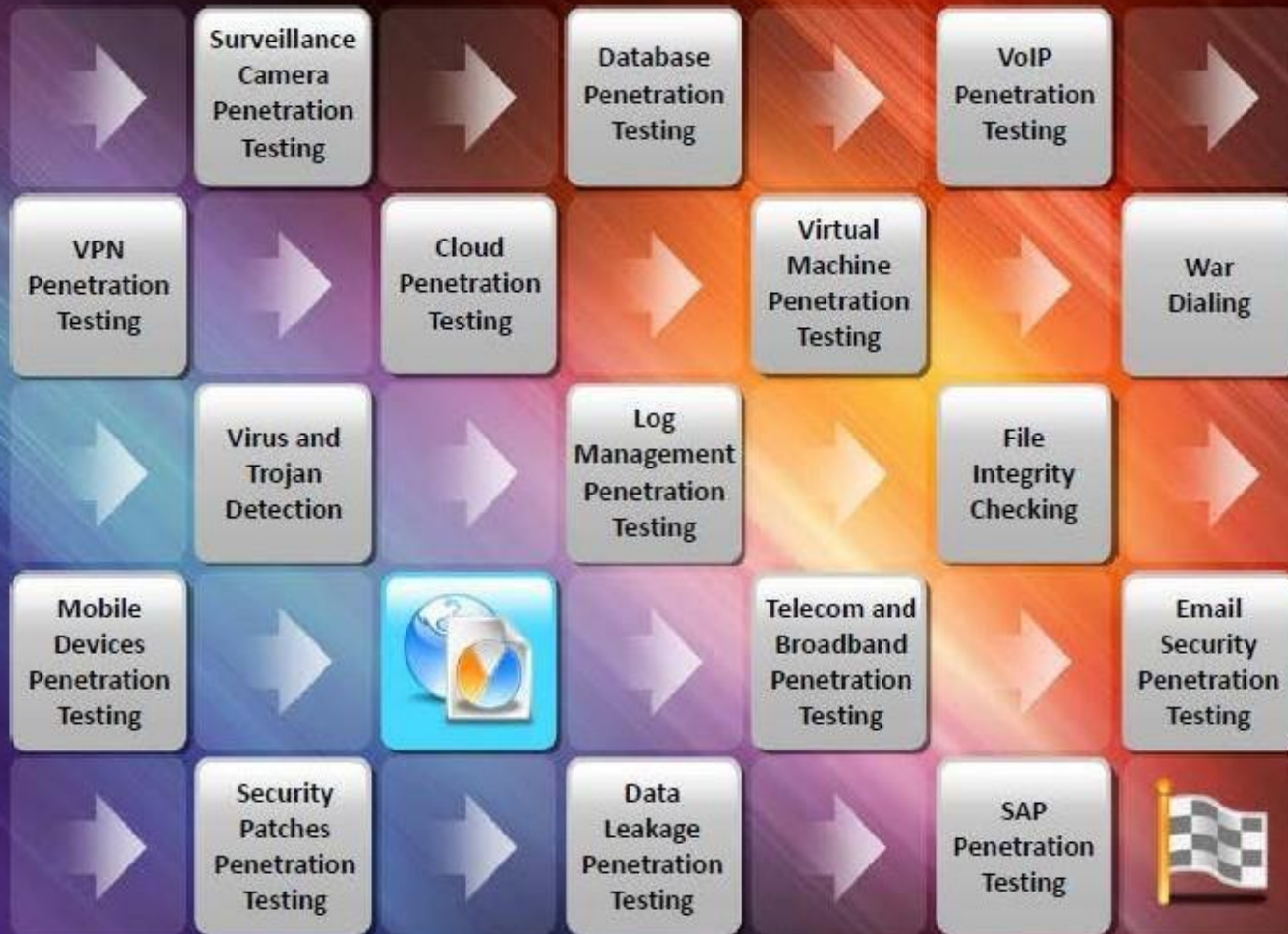


Penetration Testing





Penetration Testing





Thank You

